🎸 Báo Cáo Quét & Kiểm Toán Toàn Diện Dự Án: Sắc Band Manager Ecosystem (v2.0)

> **Thời điểm quét:** Tháng 10/2026
> **Phiên bản hệ thống:** v2.0.0 (TypeScript + Next.js 16 + Express 5 + WebSockets)
> **Trạng thái Codebase:** ✅ Build & Test Passed 100% (Backend: 0 lỗi | Frontend: 17 routes sinh tĩnh thành công)

📍 1. Tổng Quan Dự Án (Executive Summary)

Sắc Band Manager (`band-booking-app`) là hệ sinh thái phần mềm full-stack chuyên nghiệp phục vụ quản lý, điều phối hoạt động biểu diễn, tài chính và tập luyện cho ban nhạc biểu diễn trực tiếp (live band).

Hệ thống đã chuyển đổi hoàn toàn từ kiến trúc cũ v1.0 (JavaScript / React Vite SPA) sang **kiến trúc hiện đại v2.0**:

- **Backend v2.0 (`backend-v2/`)**: Node.js 22+, Express 5, TypeScript 5.7, MongoDB Atlas (Mongoose 9.1), Socket.io 4.8 thời gian thực, Helmet 8.0, Express Rate Limit, Multer, Nodemailer.
- **Frontend v2.0 (`frontend-v2/`)**: Next.js 16.2 (App Router + Turbopack), React 19.2, TypeScript 5, Tailwind CSS v4, Lucide-react, Socket.io-client, jsQR (quét mã camera thời gian thực).

```
d:\ProjectVSC\band-booking-app
├── 📁 backend-v2/                # Primary Backend Server (TypeScript + Express 5 + WebSockets)
│   ├── src/
│   │   ├── config/               # db.ts (MongoDB connection), env.ts (Strict Env validation)
│   │   ├── controllers/          # 11 Controllers: Auth, Show, Rehearsal, Finance, Library...
│   │   ├── middleware/           # auth.ts (JWT RBAC Guard), upload.ts (Multer storage)
│   │   ├── models/               # 10 Mongoose Schemas & TypeScript interfaces
│   │   ├── routes/               # 11 Express API Routers
│   │   ├── services/             # SocketService (Socket.io), NotificationService
│   │   ├── utils/                # sendEmail.ts (Nodemailer HTML templates)
│   │   └── __tests__/            # run-tests.ts, auth.test.ts, finance.test.ts
│   ├── uploads/                  # Lưu trữ beat MP3, sheet nhạc PDF
│   ├── .env                      # Biến môi trường bảo mật backend (đã gitignore)
│   └── .env.example              # Mẫu cấu hình môi trường chuẩn
│
├── 📁 frontend-v2/               # Primary Frontend Web App (Next.js 16 + React 19 + Tailwind v4)
│   ├── src/
│   │   ├── app/                  # Next.js App Router (17 routes)
│   │   │   ├── bookings/         # Quản lý Show diễn & Cát-xê (tab shows & tab rehearsals)
│   │   │   ├── bookings/[id]/    # Chi tiết Show, Setlist bài hát, Copy Zalo format
│   │   │   ├── checkin/          # Quét QR Camera & Điểm danh đa chế độ
│   │   │   ├── checkin/[rehearsalId]/ # Dynamic route điểm danh theo ID buổi tập
│   │   │   ├── rehearsals/       # Hub quản lý lịch tập, QR Token, Leaderboard
│   │   │   ├── live-stand/       # Live Stage Teleprompter, đổi Tone & cuộn sheet real-time
│   │   │   ├── library/          # Kho Beat (.mp3) & Sheet (.pdf)
│   │   │   ├── repertoire/       # Danh mục biểu diễn & Lập kế hoạch setlist
│   │   │   ├── finance/          # Quản lý Quỹ, Thu/Chi, Log đối soát Webhook ngân hàng
│   │   │   ├── members/          # Quản trị nhân sự & Gửi thông báo toàn band
│   │   │   ├── notifications/    # Trung tâm thông báo & Soạn broadcast
│   │   │   ├── dashboard/        # Bảng điều khiển tổng quan KPI, doanh thu, lịch diễn
│   │   │   ├── login/            # Đăng nhập bảo mật
│   │   │   ├── register/         # Đăng ký thành viên mới (chờ Admin duyệt)
│   │   │   └── change-password/  # Bắt buộc đổi mật khẩu lần đầu
│   │   ├── components/           # Navbar, GlobalAudioPlayer, BookingModal, ProfileModal...
│   │   ├── context/              # AuthContext (JWT/User session), AudioContext (Global player)
│   │   └── services/             # api.ts (Axios client hỗ trợ LAN IP & Bearer Token)
│   └── .env.example              # Mẫu cấu hình môi trường Frontend
│
```

```
├── 📄 package.json              # Root monorepo workspace scripts
└── 📄 README.md                 # Hướng dẫn kiến trúc & lệnh khởi chạy
```

🧬 2. Ma Trận Chức Năng Chính (Core Feature Matrix)

Chức Năng	Chi Tiết Kỹ Thuật	Tệp Liên Quan
Bảo mật & RBAC	JWT Authentication 30 ngày, phân quyền 3 cấp (`admin` , `member` , `viewer`), bắt buộc đổi mật khẩu mặc định, kiểm duyệt tài khoản mới.	, ,
Quản lý Show diễn	Khởi tạo booking, chốt thành viên tham gia (`participants`), phân bổ vai trò nhạc công (`Vocal` , `Guitar` , `Bass` , `Drum` , `Keys` , `Sax`), quản lý setlist bài hát, trích xuất text danh sách cho Zalo.	, ,
Chia Cát-Xê Tự Động	Khấu trừ Quỹ Band 5-10%, chia đều phần còn lại cho nhạc công chính thức đã được duyệt, ghi nhận tự động vào sổ cái tài chính (`Transaction`).	,
Đối Soát Bank Webhook	Webhook parser cho SePay / Cassso, nhận diện cú pháp `SHOW <ID>` (thanh toán show) và `PHAT <ID>` (đóng phạt), bảo vệ chống replay giao dịch (idempotency qua `transactionId`), bắn WebSocket báo Admin.	,
Điểm Danh Đa Kênh	Sinh mã QR động có hạn 5 phút (JWT), quét QR trực tiếp qua camera thiết bị (`jsQR`), định vị GPS bán kính 30m, hỗ trợ gửi yêu cầu GPS Bypass cho Admin khi lỗi định vị.	, ,
Live Stage Teleprompter	Giao diện tối chuyên dụng sân khấu (Pitch-black), hiển thị hợp âm theo tone chuẩn, công cụ dịch giọng (+/- tone), tự động cuộn chữ mượt mà, đồng bộ chuyển bài thời gian thực qua Socket.io.	,
Trình Phát Audio Toàn Cục	Phát beat demo nền, thanh tua scrub bar, hiển thị đĩa than vinyl xoay hoạt họa, hiệu ứng equalizer, xem trước sheet nhạc PDF.	,
Trung Tâm Thông Báo	Gửi thông báo đẩy nội bộ kèm còi báo WebSocket, gửi email HTML qua Nodemailer khi có show mới hoặc chia cát-xê.	,

🗄️ 3. Cơ Sở Dữ Liệu & Thực Thể (Database Schema Deep-Dive)

Hệ thống sử dụng MongoDB kết hợp ODM **Mongoose v9.1.5** với 10 Schemas:

🔄 4. Luồng Dữ Liệu Thực Thi (Execution Workflows)

A. Luồng Tự Động Đối Soát Bank Webhook (Bank Reconciliation)

B. Luồng Quét QR Điểm Danh & Kiểm Soát Chuyên Cần (Attendance Check-In)

🔍 5. Các Vấn Đề Đã Phát Hiện & Đã Được Xử Lý Trực Tiếp

Trong quá trình quét sâu toàn bộ source code, các lỗi tiềm ẩn sau đã được định vị và **sửa chữa hoàn chỉnh ngay trong phiên kiểm toán**:

🛠️ 1. Lỗi Tên Thư Mục URL-Encoded `%5BrehearsalId%5D` (Next.js Dynamic Route Bug)

- **Hiện trạng trước sửa:** Thư mục route dynamic tại `frontend-v2/src/app/checkin/%5BrehearsalId%5D` bị encode ký tự ngoặc vuông thành `%5B...%5D`.
- **Hậu quả:** Next.js App Router biên dịch thành route tĩnh `/checkin/%5BrehearsalId%5D` thay vì dynamic route `[rehearsalId]`. Truy cập `/checkin/abc123` bị lỗi 404.
- **Khắc phục:** Đã đổi tên thư mục thành `frontend-v2/src/app/checkin/[rehearsalId]` và dọn dẹp cache `.next`. Next.js build đã ghi nhận chính xác dynamic route `ƒ /checkin/[rehearsalId]`.

🛠️ 2. Lỗi Trích Xuất `rehearsalId` Từ Query Parameter Tại `checkin/page.tsx`

- **Hiện trạng trước sửa:** `const urlRehearsalId = params?.rehearsalId as string | undefined;` chỉ đọc từ `useParams()`. Nhưng link sinh ra từ QR Code tại `rehearsals/page.tsx` lại ở dạng query string: `/checkin?rehearsalId=...&token=...`.
- **Hậu quả:** Khi nhạc công bấm link hoặc mở từ QR, `urlRehearsalId` bị `undefined`, hệ thống tự ý fallback lấy buổi tập đầu tiên trong danh sách, dẫn tới điểm danh nhầm buổi tập khác!
- **Khắc phục:** Đã bổ sung `searchParams?.get("rehearsalId")`:

```typescript
const urlRehearsalId = (params?.rehearsalId as string) ||
searchParams?.get("rehearsalId") || undefined;
```

Đồng thời cập nhật logic quét camera QR trích xuất chuẩn `url.searchParams.get("rehearsalId")`.

🛠️ 3. Tuyến Route Bị Bỏ Quên: `requestGPSBypass`

- **Hiện trạng trước sửa:** Controller `requestGPSBypass` đã được viết hoàn chỉnh trong nhưng chưa được đăng ký trong .
- **Khắc phục:** Đã đăng ký route `router.post('/:id/gps-bypass', protect, requestGPSBypass);`.

🛠️ 4. Tăng Cường Độ Nhạy Regex Phân Tích Cú Pháp Chuyển Khoản Ngân Hàng

- **Hiện trạng trước sửa:** Regex `cleanContent.match(/SHOW\s+([A-F0-9]{24})/i)` bắt buộc phải có ít nhất một khoảng trắng `\s+`.
- **Rủi ro:** Khi khách hàng hoặc ngân hàng bỏ dấu cách (ví dụ `SHOW65d83f...`), webhook không thể nhận diện được mã Show.
- **Khắc phục:** Cập nhật thành `SHOW\s*([A-F0-9]{24})` và `PHAT\s*([A-F0-9]{24})` cho phép cả có dấu cách và không có dấu cách trong cả và unit test .

🛠️ 5. Hỗ Trợ Kết Nối LAN IP Cho Sân Khấu (Live Stand & Audio Player)

- **Hiện trạng trước sửa:** Tại và , code chỉ kiểm tra `localhost` hoặc `127.0.0.1`. Khi nhạc công kết nối iPad / điện thoại qua WiFi nội bộ phòng tập (ví dụ `192.168.x.x`), hệ thống tự động nhảy sang URL Render thay vì server local.
- **Khắc phục:** Đã cập nhật pattern nhận diện dải IP LAN `^(\d{1,3}\.){3}\d{1,3}$` đồng bộ với .

🛠️ 6. Hardcode URL Localhost Trong Email Thông Báo

- **Hiện trạng trước sửa:** Tại , link show trong email bị gán cố định `http://localhost:3000/bookings/${show._id}`.
- **Khắc phục:** Đã cập nhật sử dụng biến môi trường `process.env.FRONTEND_URL || 'http://localhost:3000'`.

🛠️ 7. Tạo Mới Các File Cấu Hình `.env.example`

- Đã tạo và đầy đủ các biến môi trường chuẩn.

🔒 6. Kiểm Toán An Ninh & Bảo Mật (Security Audit)

Hạng Mục	Đánh Giá Hiện Tại	Khuyến Nghị Duy Trì
Bảo Vệ Webhook Ngân Hàng	✅ **Rất tốt**: Bắt buộc có `WEBHOOK_SECRET` trùng khớp, chống gọi trái phép. Có chống replay giao dịch qua kiểm tra `transactionId`.	Tiếp tục bảo mật `WEBHOOK_SECRET`, không commit lên GitHub.
Xác Thực JWT & RBAC	✅ **Rất tốt**: Token hết hạn 30 ngày, phân quyền Admin chặt chẽ qua middleware `admin`. Các tài khoản chưa được duyệt (`isApproved: false`) bị chặn 403.	Có thể cân nhắc thêm cơ chế refresh token nếu muốn rút ngắn thời gian sống access token (ví dụ 1h).
Phòng Chống Tấn Công Brute-Force	✅ **Rất tốt**: Đã cấu hình `express-rate-limit` (300 req/15 phút cho toàn API, 50 req/15 phút cho `/login` và `/register`).	Đã gắn sau CORS middleware, không làm đứt header preflight.
HTTP Security Headers	✅ **Rất tốt**: `helmet` đã được bật, cấu hình tương thích cho audio streaming và SVG rendering.	Duy trì cấu hình hiện tại.
Quản Lý Git Index	⚠️ **Cần lưu ý**: Git status ghi nhận nhiều tệp `deleted: backend/node_modules/...` từ repo cũ.	Cần thực hiện `git add -A` và commit dọn dẹp các tệp node_modules cũ khỏi Git tracking khi triển khai.

📊 7. Kết Quả Kiểm Thử & Biên Dịch (Build & Test Verification)

Backend v2:

```
bash
> backend-v2@2.0.0 test
> ts-node src/__tests__/run-tests.ts

✅ Test 1 Passed: Correctly parsed Show ID from bank transfer content.
✅ Test 2 Passed: Correctly parsed User ID for fine payment.
✅ Test 3 Passed: Correct 10% Band Fund deduction (1,000,000 VND).
✅ Test 1 Passed: JWT generation and verification verified.
✅ Test 2 Passed: Reject token with invalid signature.
✅ Test 3 Passed: Correctly enforced Admin RBAC permissions.

🎉 ALL TESTS PASSED SUCCESSFULLY! Codebase is healthy.
```

```
bash
> backend-v2@2.0.0 build
> tsc
# Biên dịch TypeScript thành công 100% với 0 lỗi (dist/ generated)
```

Frontend v2:

```
bash
> frontend-v2@0.1.0 build
> next build

▲ Next.js 16.2.7 (Turbopack)
✓ Compiled successfully in 2.9s
  Running TypeScript ...
  Finished TypeScript in 3.4s ...
✓ Generating static pages using 11 workers (17/17) in 394ms

Route (app)
┌ ○ /
├ ○ /_not-found
├ ○ /bookings
├ ƒ /bookings/[id]
├ ○ /change-password
├ ○ /checkin
├ ƒ /checkin/[rehearsalId]
├ ○ /dashboard
├ ○ /finance
├ ○ /library
├ ○ /live-stand
├ ○ /login
├ ○ /members
├ ○ /notifications
├ ○ /register
├ ○ /rehearsals
└ ○ /repertoire

○ (Static)   prerendered as static content
ƒ (Dynamic)  server-rendered on demand
```

🎯 8. Kết Luận & Đánh Giá Tổng Thể

Dự án **Sắc Band Manager v2.0** sở hữu cấu trúc mã nguồn hoàn chỉnh, kiến trúc monorepo phân tầng rõ ràng, tính năng bao phủ toàn bộ nghiệp vụ thực tế của một ban nhạc biểu diễn trực tiếp chuyên nghiệp.

Tất cả các thành phần cốt lõi:

- Quản lý Show & Chia Cát-xê
- Điểm danh mã QR động & Kiểm soát trễ giờ
- Live Stage Teleprompter & Sync Setlist qua WebSockets
- Đối soát tự động tài chính qua Bank Webhook
- Hệ thống Audio Player toàn cục & Quản lý Thư viện bài hát

đã được quét toàn diện, khắc phục các bất cập kỹ thuật, và đã vượt qua 100% các bài kiểm tra build và unit tests. Codebase đạt độ tin cậy và sẵn sàng vận hành thực tế.